

Análisis de riesgos

1. Seguridad de Sesiones y Contraseñas.

Actualmente, cuando un usuario oprime "Cerrar sesión", el sistema únicamente borra el token de acceso de su navegador local. El servidor backend no tiene una lista negra para invalidar ese token; esto significa que si alguien se robara ese código (token) antes de que expire, podría seguir haciendo peticiones malignas simulando ser el administrador, incluso si el administrador ya cerró su computadora.

2. Fragilidad entre Microservicios (BFF).

El portal web no se conecta directamente a los microservicios, sino que usa un intermediario (el BFF Service). El riesgo aquí es que estas conexiones son asíncronas y directas sin un "cortacircuitos" (Circuit Breaker). Si el microservicio de la biblioteca se cae o se vuelve muy lento, el BFF se quedará esperando, lo que podría congelar toda la aplicación o saturar la memoria del servidor intermediario esperando respuestas fantasma.

3. Validaciones de Entrada Muy Básicas.

El sistema confía demasiado en que el usuario o el Frontend enviará siempre los datos correctos. El Backend hace validaciones muy simples (ej. confirmar si el título "no está vacío"). Al no utilizar librerías estrictas de validación de esquemas estructurales, existe el riesgo de que datos corruptos, formatos inválidos o textos excesivamente largos logren colarse hasta la base de datos si la aplicación web es vulnerada.